



PRIDE
SECURITY

ASPM com Inteligência Artificial

Application Security Posture Management

FIAP Challenge 2026

ASPM Inteligente da PRIDE Security

Essencial:

- **Integração em todo ciclo de desenvolvimento.**
- **Inventário automatizado** com IA para descoberta de ativos.
Identificação e gestão de vulnerabilidades, integração com CI, CD, etc.
- **Orquestração SAST/DAST/Pentest** com priorização por IA (LLM, ML, etc).
- **Proteção anti-prompt injection**, detecção de credential leaks, dados sensíveis de cliente, etc.
- **Integração** com ferramentas de mercado (ex.: Semgrep, Burp Suite, Nessus, Qualys, etc).

Tecnologias de IA Aplicadas

Machine Learning

Detecção de anomalias, classificação de riscos e redução de falsos positivos

NLP & LLMs

Análise de código-fonte, geração de remediações e threat intelligence

Computer Vision

Testes automatizados de UI e validação visual de segurança

Proposta Comercial

SaaS por Ativos

Pricing escalável baseado em número de aplicações monitoradas

Compliance First

SOC2, ISO 27001 e licenças comerciais validadas

Diferencial: IA multi-modal + visibilidade unificada

ASPM - Fundamentos (Parte 1)

ASPM (Application Security Posture Management)

Abordagem holística para gerenciar continuamente riscos de segurança em aplicações através de visibilidade centralizada, correlação de dados e priorização inteligente de vulnerabilidades.

Asset Discovery

Processo automatizado de identificação de todos os ativos de aplicações em um ambiente, incluindo shadow IT e aplicações esquecidas que representam riscos de segurança.

Security Posture

Estado geral de segurança de uma organização, avaliando vulnerabilidades, configurações, controles e capacidade de resposta a ameaças.

ASPM - Fundamentos (Parte 2)

Risk Correlation

Capacidade de associar múltiplos sinais de segurança de diferentes ferramentas para identificar o impacto real e explorabilidade de vulnerabilidades no contexto do ambiente de produção.

Tool Orchestration

Coordenação automatizada de múltiplas ferramentas de segurança (SAST, DAST, SCA, pentest) através de workflows integrados e aplicação consistente de políticas de segurança.

Security Signal

Indicador de potencial vulnerabilidade ou risco detectado por ferramentas de segurança, tratado como hipótese que precisa validação contextual antes de ação.

Testes de Segurança (Parte 1)

SAST (Static Application Security Testing)

Análise de código-fonte ou binários sem executar a aplicação, identificando vulnerabilidades através de padrões, fluxo de dados e análise sintática durante o desenvolvimento.

DAST (Dynamic Application Security Testing)

Teste de segurança em aplicações em execução simulando ataques reais (black-box), sem acesso ao código-fonte, identificando vulnerabilidades exploráveis em runtime.

IAST (Interactive Application Security Testing)

Monitoramento de aplicações durante testes ou runtime através de instrumentação de código, combinando visibilidade interna (white-box) com simulação de ataques.

Testes de Segurança (Parte 2)

SCA (Software Composition Analysis)

Análise de componentes de terceiros e dependências open-source, identificando vulnerabilidades conhecidas (CVEs), licenças incompatíveis e riscos de supply chain.

RASP (Runtime Application Self-Protection)

Tecnologia integrada à aplicação que detecta e bloqueia ataques em tempo real durante execução, com contexto interno completo sobre fluxo de dados e comportamento.

IaC Scanning

Análise de código de infraestrutura (Terraform, CloudFormation, Kubernetes) para identificar configurações inseguras antes do deployment em ambientes cloud.

Vulnerabilidades e Riscos

CVE (Common Vulnerabilities and Exposures)

Sistema de identificação padronizado para vulnerabilidades de segurança conhecidas publicamente, mantido pela MITRE Corporation com IDs únicos (ex: CVE-2024-1234).

CVSS (Common Vulnerability Scoring System)

Framework padronizado para avaliar severidade de vulnerabilidades através de score 0-10, considerando explorabilidade, impacto e características temporais e ambientais.

Zero-Day Vulnerability

Vulnerabilidade desconhecida pelo fornecedor do software, sem patch disponível, sendo ativamente explorada por atacantes antes da descoberta pública.

Supply Chain e Compliance

Supply Chain Attack

Comprometimento de aplicações através de dependências ou fornecedores confiáveis, como bibliotecas open-source maliciosas ou ferramentas de build infectadas.

SBOM (Software Bill of Materials)

Inventário completo de componentes, bibliotecas e dependências de uma aplicação, crucial para rastreabilidade, gestão de vulnerabilidades e compliance regulatório.

False Positive

Alerta de segurança incorreto onde a ferramenta identifica vulnerabilidade inexistente, gerando ruído e desperdício de esforço na triagem e remediação.

IA - Machine Learning (Parte 1)

Machine Learning (ML)

Subcampo de IA onde algoritmos aprendem padrões a partir de dados sem programação explícita, usado em ASPM para classificação de riscos, detecção de anomalias e redução de falsos positivos.

Anomaly Detection

Técnica de ML que identifica desvios de padrões normais de comportamento em aplicações, detectando atividades suspeitas, exfiltração de dados ou ataques desconhecidos.

Risk Scoring

Aplicação de modelos ML para calcular prioridade de vulnerabilidades baseado em contexto (exposição, criticidade do ativo, explorabilidade), além do CVSS tradicional.

IA - Machine Learning (Parte 2)

Supervised Learning

Treinamento de modelos ML com dados rotulados (ex: vulnerabilidades confirmadas vs falsos positivos) para classificação e predição em novos dados de segurança.

Unsupervised Learning

Técnicas ML que descobrem padrões ocultos em dados não rotulados, útil para clustering de vulnerabilidades similares e identificação de comportamentos anômalos desconhecidos.

Model Training

Processo de alimentar algoritmos ML com datasets históricos de vulnerabilidades, ataques e remediações para otimizar performance e acurácia de predições de risco.

IA - NLP e LLMs (Parte 1)

NLP (Natural Language Processing)

Campo de IA focado em processar e entender linguagem humana, aplicado em ASPM para análise de documentação, threat intelligence e geração automática de remediações.

LLM (Large Language Model)

Modelos de linguagem massivos (GPT, Claude, Gemini) treinados em trilhões de tokens, capazes de compreensão contextual, geração de código e análise de vulnerabilidades em código-fonte.

Code Analysis

Uso de LLMs para revisar código-fonte identificando vulnerabilidades semânticas, lógica insegura e padrões anti-segurança que ferramentas SAST tradicionais não detectam.

IA - NLP e LLMs (Parte 2)

Threat Intelligence

Processamento automático via NLP de relatórios de segurança, CVEs, artigos técnicos e feeds de ameaças para correlacionar riscos emergentes com vulnerabilidades do ambiente.

Remediation Generation

Capacidade de LLMs gerarem automaticamente patches de código, configurações corrigidas e recomendações contextualizadas de remediação para vulnerabilidades identificadas.

Semantic Understanding

Habilidade de modelos NLP/LLM compreenderem significado e intenção do código além da sintaxe, detectando lógicas de negócio inseguras e fluxos de dados maliciosos.

IA - Computer Vision

Computer Vision

Técnicas de IA para processamento e análise de imagens, aplicadas em testes automatizados de UI, validação visual de segurança e detecção de elementos sensíveis em interfaces.

UI Security Testing

Uso de modelos de visão computacional para validar automaticamente fluxos de autenticação, detecção de XSS refletido em interfaces e vazamento visual de dados sensíveis.

Visual Regression Testing

Comparação automatizada de screenshots de aplicações para identificar alterações não intencionais que podem introduzir vulnerabilidades de segurança em UIs.

Ataques contra IA (Parte 1)

Prompt Injection

Ataque onde inputs maliciosos manipulam instruções de LLMs para ignorar restrições de segurança, exfiltrar system prompts ou executar ações não autorizadas (OWASP LLM01).

Jailbreaking

Técnicas para contornar guardrails e políticas de segurança de LLMs através de prompts adversariais, obtendo respostas proibidas ou gerando conteúdo malicioso.

System Prompt Leakage

Exfiltração de instruções internas (system prompts) de aplicações LLM, revelando lógica de negócio, políticas de segurança e informações confidenciais da organização (OWASP LLM07).

Ataques contra IA (Parte 2)

Data Poisoning

Injeção de dados maliciosos durante treinamento ou fine-tuning de modelos ML/LLM para introduzir backdoors, vieses ou comprometer comportamento em produção (OWASP LLM04).

Model Extraction

Técnicas de engenharia reversa para replicar modelos proprietários através de queries sistemáticas, roubando propriedade intelectual e facilitando ataques adversariais.

Adversarial Attack

Manipulação de inputs para enganar modelos ML, como perturbações imperceptíveis em imagens que causam classificação errada ou evasão de detecção de malware.

Ataques contra IA (Parte 3)

Credential Leakage

Exposição de segredos (API keys, tokens, senhas) através de outputs de LLMs que memorizam dados sensíveis de treinamento ou concatenam informações de contexto (OWASP LLM02).

RAG Poisoning

Inserção de documentos maliciosos em bases de conhecimento RAG (Retrieval-Augmented Generation) para manipular respostas de LLMs e exfiltrar dados através de queries controladas.

Tool Abuse

Exploração de LLMs com acesso a ferramentas externas (APIs, databases, shell) para executar ações maliciosas através de prompts que manipulam chamadas de funções.

Segurança de IA

LLM Pentesting

Avaliação estruturada de segurança de aplicações LLM testando prompt injection, jailbreak, exfiltração de dados, abuse de ferramentas e validação de guardrails.

Guardrails

Controles de segurança que validam inputs e outputs de LLMs, bloqueando prompts maliciosos, filtrando conteúdo sensível e aplicando políticas de uso aceitável.

OWASP LLM Top 10

Catálogo dos 10 riscos críticos em aplicações LLM: prompt injection, vazamento de dados, vulnerabilidades de supply chain, data poisoning, output handling inseguro, entre outros.

DevSecOps e SDLC

DevSecOps

Integração de práticas de segurança em todo ciclo de desenvolvimento, automatizando testes de segurança em CI/CD e promovendo responsabilidade compartilhada entre dev, sec e ops.

Shift-Left Security

Filosofia de identificar e corrigir vulnerabilidades o mais cedo possível no SDLC, reduzindo custo e complexidade de remediação através de SAST/SCA em desenvolvimento.

CI/CD Security

Proteção de pipelines de integração e deployment contínuos contra comprometimento, incluindo validação de código, scanning de containers e secrets management automatizado.

Cloud e Containers

Container Security

Proteção de imagens Docker/containers através de scanning de vulnerabilidades em base images, validação de runtime policies e isolamento de workloads em Kubernetes.

CSPM (Cloud Security Posture Management)

Monitoramento contínuo de configurações de infraestrutura cloud (AWS, Azure, GCP) para identificar misconfigurations, violações de compliance e exposições de segurança.

API Security

Proteção de interfaces de programação contra OWASP API Top 10: broken authentication, excessive data exposure, injection, rate limiting insuficiente e misconfiguration.

Arquitetura e Integrações

Single Pane of Glass

Interface unificada em ASPM que agrega dados de múltiplas ferramentas de segurança (SAST, DAST, SCA, pentest) em dashboard centralizado para visibilidade holística.

Security Orchestration

Automação de workflows de segurança conectando ferramentas díspares, criando pipelines de triagem, priorização e remediação sem intervenção manual excessiva.

SIEM Integration

Integração de plataformas ASPM com Security Information and Event Management para correlação de vulnerabilidades de aplicações com eventos de runtime e incidentes de segurança.